

TP 4 : Cassage de Mot de Passe

ISC_125 – Sécurité des systèmes d'information et cryptographie

Ludovico Grabau et Valentin Acevedo

01.06.2021

Table des matières

De quoi s'agit-il	2
Démarche, résultats et réponses.....	2
Questions théoriques initiales.....	2
1. Mots de passe faible – mode « single »	5
2. Attaque par dictionnaire	7
3. Mots de passe par décalage	9
4. Hachage par SHA512	11
5. Analyse des performances des hashes.....	12
Conclusion.....	13
Sources	14

De quoi s'agit-il

John the Ripper est un logiciel libre de cassage de mots de passe par dictionnaire. Il permet de tester le niveau de sécurité d'un mot de passe. Le but de ce TP est de se familiariser avec cet outil, et de comprendre les stratégies élémentaires de brute forcing.

Démarche, résultats et réponses

Mise en situation :

Vous êtes mandaté pour tester la sécurité d'une petite *ONG* de 7 personnes. Cet organisme de défense des animaux souhaite tester en particulier la robustesse de leur mot de passe.

Votre objectif est donc de trouver ces mots de passes à l'aide d'information glanée soit pendant votre entretien, soit en discutant avec les différents collaborateurs (le *social engineering* est une part réelle et non-négligeable de la cybersécurité). Ces informations sont exposées dans ce document.

Questions théoriques initiales

- Vérifier que John the Ripper est installé. Quelle commande avez-vous utilisée ?

→ `sudo apt show john`

```
(kali@kali)~$ sudo apt show john
[sudo] password for kali:
Package: john
Version: 1.9.0-Jumbo-1-0kali3
Priority: optional
Section: admin
Maintainer: Kali Developers <devel@kali.org>
Installed-Size: 78.9 MB
Depends: libc6 (≥ 2.14), libgmp10, libgomp1 (≥ 4.9), libpcap0.8 (≥ 0.9.8), libssl1.1 (≥ 1.1.0), zlib1g (≥ 1:1.1.4), john-data (= 1.9.0-Jumbo-1-0kali3)
Suggests: wordlist
Homepage: https://github.com/magnumripper/JohnTheRipper
Download-Size: 12.9 MB
APT-Manual-Installed: yes
APT-Sources: http://http.kali.org/kali kali-rolling/main amd64 Packages
Description: active password cracking tool
 John the Ripper is a tool designed to help systems administrators to
 find weak (easy to guess or crack through brute force) passwords, and
 even automatically mail users warning them about it, if it is desired.
 .
 Besides several crypt(3) password hash types most commonly found on
 various Unix flavors, supported out of the box are Kerberos AFS and
 Windows NT/2000/XP/2003 LM hashes, plus several more with contributed
 patches.
```

→ sudo apt install john

```
(kali㉿kali)-[/usr/sbin]
└─$ sudo apt install john
[sudo] password for kali:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
john is already the newest version (1.9.0-Jumbo-1-0kali3).
0 upgraded, 0 newly installed, 0 to remove and 3 not upgraded.
```

- Identifier et donner l'emplacement du fichier de configuration de John the Ripper.

→ whereis john

```
(kali㉿kali)-[/usr/sbin]
└─$ whereis john
john: /usr/sbin/john /usr/lib/john /etc/john /usr/share/john /usr/share/man/man8/john.8.gz
```

```
(kali㉿kali)-[/usr/sbin]
└─$ pwd
/usr/sbin
```

```
(kali㉿kali)-[/usr/sbin]
└─$ ls
a2disconf      ctrlaltdel    get-oui       isosize
a2dismod       curvetun      getpcaps      ispell-autobuildhash
a2dissite      debian-update-rc.d  getty         iucode-tool
a2enconf       debugfs       gparted       iucode_tool
a2enmod        delgroup      gpartedbin    iw
a2ensite       deluser       gpg2john      iwconfig
a2query        depmod        groupadd       iwevent
aa-remove-unknown  devlink      groupdel       iwgetid
aa-status      dhclient      groupmems     iwlist
aa-teardown    dhclient-script  groupmod      iwpriv
accessdb       dm2john       grpck         iwspy
addgnupghome   dmidecode     grpconv       jffs2dump
addgroup       dmsetup       grpunconv     jffs2reader
add-shell      dmstats       grub-bios-setup  john
```

1

¹ <https://linuxconfig.org/password-cracking-with-john-the-ripper-on-linux>

- *Que signifie MD5 ? Quelle est la taille de son empreinte ? Que signifie “sans sel” (ou, dans l’énoncé, « non-salé ») ? Est-il aujourd’hui un protocole sécurisé ?*

MD5 signifie « Message Digest 5 », la taille de son empreinte est de 128 bits.

Sans sel signifie que l’on n’ajoute pas l’élément appelé « sel » qui est un nombre contenu dans notre information pour faire varier le hash, le rendant unique et donc plus difficile à retrouver, permettant de ralentir les attaques par brute forcing.

Non aujourd’hui ça ne l’est plus.

- *Que signifie SHA512 ? Quelle est la taille de son empreinte ? Est-il aujourd’hui sécurisé ?*

SHA512 signifie “Secure Hash Algorithm” pour 512 bits. Sa taille est par conséquent 512 bits. Non, aujourd’hui il n’est plus autant sécurisé.

1. Mots de passe faible – mode « single »

- *Essayer de casser ce mot de passe en mode "single" de John the Ripper. Que signifie le mode single ?*

```
(kali㉿kali)-[~/Downloads]
$ john --single password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 5 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 17 candidates buffered for the current salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 3 candidates buffered for the current salt, minimum 24 needed for performance.
0g 0:00:00:00 DONE (2021-06-05 14:48) 0g/s 213550p/s 213550c/s 1067KC/s alexandra1900..marie1900
Session completed

(kali㉿kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1

1 password hash cracked, 5 left
```

"Single crack" mode.

This is the mode you should start cracking with. It will use the login names, "GECOS" / "Full Name" fields, and users' home directory names as candidate passwords, also with a large set of mangling rules applied. Since the information is only used against passwords for the accounts it was taken from (and against password hashes which happened to be assigned the same salt), "single crack" mode is much faster than wordlist mode. This permits for the use of a much larger set of word mangling rules with "single crack", and their use is always enabled with this mode. Successfully guessed passwords are also tried against all loaded password hashes just in case more users have the same password.

Note that running this mode on many password files simultaneously may sometimes get more passwords cracked than it would if you ran it on the individual password files separately.

2

² <https://www.openwall.com/john/doc/MODES.shtml>

It's using information it already has available.

```
admin:admin
```

Single crack : In this mode, john will try to crack the password using the login/GECOS information as passwords.

From [Linux Password Cracking](#)

Found as a result from [Google Search](#).

The typical format for the GECOS field is a comma-delimited list with this order:

1. User's full name (or application name, if the account is for a program)
2. Building and room number or contact person
3. Office telephone number
4. Any other contact information (pager number, fax, etc.)

In most of the UNIX systems this information can be changed by normal users using the `chfn` command from the shell.

From [Wikipedia](#)

If the target is more advanced in their password creation, then `single crack` mode will likely not get a hit. If you have a dictionary of other passwords the user has used it will prove much more fruitful.

3 4 5 6

³ <https://security.stackexchange.com/questions/37072/what-exactly-is-single-mode-in-john-the-ripper-doing>

⁴ <http://www.cyberciti.biz/faq/unix-linux-password-cracking-john-the-ripper/>

⁵ <https://www.google.com/search?q=%22single%20crack%22%20mode%20%22john%20the%20ripper%22>

⁶ http://en.wikipedia.org/wiki/Gecos_field

2. Attaque par dictionnaire

- Le deuxième utilisateur a choisi son animal préféré comme mot de passe. Pour le trouver, vous vous aidez d'une liste d'animaux extraites d'internet : le fichier `dictionnaire.txt`

```
(kali㉿kali)-[~/Downloads]
$ john --wordlist="animaux.txt" password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 5 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Raton laveur (marie)
1g 0:00:00:00 DONE (2021-06-05 15:57) 100.0g/s 60400p/s 60400c/s 302000C/s Moro sphinx..Zombre de Groovy
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed

(kali㉿kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1
marie:Raton laveur

2 password hashes cracked, 4 left
```

- Le troisième utilisateur se vante d'avoir trouvé un superbe moyen de protéger son mot de passe : lui aussi a choisi son animal préféré pour s'en souvenir, mais il a changé toutes les consonnes de ce dernier par un chiffre, toujours le même, choisi au hasard. Par exemple, si son animal favori était le CHAT et le chiffre le 8, on obtiendrait « 88A8 ».

```
(kali㉿kali)-[~]
$ sudo nano /etc/john/john.conf

# Remplacer toutes (=s) les consonnes (=?c) par une valeur entre 0 et 9 (=[0-9])
[List.Rules:ConsonnesChiffres]
s?c[0-9]
```

⁷ <https://miloserdov.org/?p=5477#515>

```

(kali㉿kali)-[~/Downloads]
$ john --rules=ConsonnesChiffres --wordlist=animaux.txt password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 4 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
5a555i55 (claude)
1g 0:00:00:00 DONE (2021-06-05 16:14) 100.0g/s 605000p/s 605000c/s 2160KC/s 9a9i9 9e 9a9e99e ..999e 9e 9999
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed

(kali㉿kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1
marie:Raton laveur
claude:5a555i55

3 password hashes cracked, 3 left

```

- Le quatrième a choisi à la place d'inverser les lettres de son animal, puis l'a répété une fois pour en augmenter la sécurité. Par exemple pour le CHAT => TAHCTAHC.

```

# Inverser les lettres (=r), puis répéter une seule fois (=d)
[List.Rules:InverserRepetar]
rd

```

```

(kali㉿kali)-[~/Downloads]
$ john --rules=InverserRepetar --wordlist=animaux.txt password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 3 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
etaciruSetaciruS (alexandra)
1g 0:00:00:00 DONE (2021-06-05 16:18) 100.0g/s 60100p/s 60100c/s 180300C/s tomtomtomtoM..yvRg ed erbZyvRg ed erbZ
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed

(kali㉿kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1
marie:Raton laveur
claude:5a555i55
alexandra:etaciruSetaciruS

4 password hashes cracked, 2 left

```

3. Mots de passe par décalage

- Le cinquième utilisateur a répété le nom de son animal favori trois fois d'affilé pour créer son mot de passe.

```
# Répéter 3 fois d'affilé (⇒pN (N = 2 ⇒ "0, 1, 2" = 3 fois) = p2)
[List.Rules:Repeter3]
p2
```

```
(kali@kali)-[~/Downloads]
$ john --rules=Repeter3 --wordlist=animaux.txt password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 2 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
WapitiWapitiWapiti (jacques)
1g 0:00:00:00 DONE (2021-06-05 16:31) 33.33g/s 16366p/s 16366c/s 32733C/s Porc pie noirPorc pie noirPorc pie noir..Zöbre de GrövyZöbre de GrövyZöbre de Grövy
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed

(kali@kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1
marie:Raton laveur
claudio:5a555i55
alexandra:etaciruSetaciruS
jacques:WapitiWapitiWapiti
5 password hashes cracked, 1 left
```

- Le sixième utilisateur, fan d'histoire, a décidé d'utiliser le chiffrement de César1 pour chiffrer le nom de son animal favori. Il reste persuadé que, sachant que vous ne connaissez pas sa clé, son mot de passe reste sécurisé.

```
(kali@kali)-[~/Downloads]
$ john --external=Cesar --wordlist=animaux.txt password.txt --format=RAW-MD5
Using default input encoding: UTF-8
Loaded 6 password hashes with no different salts (Raw-MD5 [MD5 256/256 AVX2 8x3])
Remaining 1 password hash
Warning: no OpenMP support for this hash type, consider --fork=2
Press 'q' or Ctrl-C to abort, almost any other key for status
Bprybg (noelle)
1g 0:00:00:00 DONE (2021-06-06 09:16) 25.00g/s 15100p/s 15100c/s 15100C/s Zbeb fcuvak..Möer qr Teil
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed

(kali@kali)-[~/Downloads]
$ john password.txt --show --format=RAW-MD5
jean:jean1
marie:Raton laveur
claudio:5a555i55
alexandra:etaciruSetaciruS
jacques:WapitiWapitiWapiti
noelle:Bprybg
6 password hashes cracked, 0 left
```

[List.External:Cesar]

```
void filter()
{
    int c;
    int i;
    int key;
    int ch;

    i = 0;
    key = 13;

    while (c = word[i])
    {
        ch = word[i];

        if (ch ≥ 'A' && ch ≤ 'Z') {
            ch = ch + key;

            if (ch > 'Z') {
                ch = ch - 'Z' + 'A' - 1;
            }

            word[i] = ch;
        }

        else if (ch ≥ 'a' && ch ≤ 'z') {
            ch = ch + key;

            if (ch > 'z') {
                ch = ch - 'z' + 'a' - 1;
            }

            word[i] = ch;
        }

        i++;
    }
}
```

8

9

⁸ <https://www.lanmaster53.com/2011/02/creating-complex-password-lists-with-john-the-ripper/>

⁹ <https://www.thecrazyprogrammer.com/2016/11/caesar-cipher-c-c-encryption-decryption.html>

4. Hachage par SHA512

- *Le dernier collaborateur, le responsable, a stocké son mot de passe sur un serveur différent : ce dernier utilise en effet SHA512 comme protocole de hachage. Toutefois, sa mémoire lui fait parfois défaut et son mot de passe doit donc être simple à retenir : il s'agit probablement simplement de son animal favori.*

```
(kali㉿kali)-[~/Downloads]
$ john --wordlist=animaux.txt --format=RAW-SHA512 password.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA512 [SHA512 256/256 AVX2 4x])
Warning: poor OpenMP scalability for this hash type, consider --fork=2
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
Rainette aux yeux rouges (laura)
1g 0:00:00:00 DONE (2021-06-05 19:09) 50.00g/s 30200p/s 30200c/s 30200C/s Abeille..Z bre de Gr vy
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

```
(kali㉿kali)-[~/Downloads]
$ john password.txt --show --format=RAW-SHA512
laura:Rainette aux yeux rouges

1 password hash cracked, 0 left
```

- *BONUS : vous pouvez vous amusez à refaire les procédures liées aux utilisateurs 1 à 6 avec SHA512. Relever les différentes statistiques*

Rien ne se passe car il y avait qu'un seul hash en SHA512 pouvant être cassé dans la liste, vu que nous l'avons déjà trouvé, ça ne sert à rien de chercher à casser autre chose de manière différente.

5. Analyse des performances des hashes

- *Établir une statistique donnant les temps de calculs des mots de passe en fonction des users.*

→ cd /home/kali/.john

→ nano john.pot (une fois le fichier ouvert, on supprime son contenu)

jean : jean1 (0:00:00:00)

marie : Raton laveur (0:00:00:00)

claire : 5a555i55 (0:00:00:00)

alexandra : etaciruSetaciruS (0:00:00:00)

jacques : WapitiWapitiWapiti (0:00:00:00)

noelle : Bprybg (0:00:00:00)

laura : Rainette aux yeux rouges (0:00:00:00)

```
jean1 (jean)
Almost done: Processing the remaining buffered candidate passwords, if any.
Warning: Only 23 candidates buffered for the current salt, minimum 24 needed for performance.
1g 0:00:00:00 DONE (2021-06-08 12:34) 50.00g/s 215650p/s 215650c/s 1087KC/s alexandra1904..marie1900

Raton laveur (marie)
1g 0:00:00:00 DONE (2021-06-08 12:35) 50.00g/s 30200p/s 30200c/s 151000C/s Moro sphinx..Zbre de Grvy

5a555i55 (claire)
1g 0:00:00:00 DONE (2021-06-08 12:35) 50.00g/s 302500p/s 302500c/s 1080KC/s 9a9i9 9e 9a9e99e ..999e 9e 9999

etaciruSetaciruS (alexandra)
1g 0:00:00:00 DONE (2021-06-08 12:36) 33.33g/s 20033p/s 20033c/s 60100C/s tomtomtomtoM..yvG ed erbZyvG ed erbZ

WapitiWapitiWapiti (jacques)
1g 0:00:00:00 DONE (2021-06-08 12:36) 50.00g/s 24550p/s 24550c/s 49100C/s Porc pie noirPorc pie noirPorc pie noir..Zbre de GrvyZbre de GrvyZbre

Bprybg (noelle)
1g 0:00:00:00 DONE (2021-06-08 12:37) 20.00g/s 12080p/s 12080c/s 12080C/s Zbeb fcuvak..Moer qr Teil

Rainette aux yeux rouges (laura)
1g 0:00:00:00 DONE (2021-06-08 12:37) 100.0g/s 60400p/s 60400c/s 60400C/s Abeille..Zbre de Grvy
```

- *Discuter de la différence de temps des performances selon les types de mots de passe et des hashes.*

Pour le coup la puissance de mon processeur est suffisant élevé pour casser des mots de passe à une vitesse ne pouvant pas être affichée correctement du au manque de précision de la mesure du temps que fait automatiquement John The Ripper, donc on se retrouve avec un temps de 0:00:00:00 pour tous les cassages de mot de passe.

Conclusion

En conclusion, nous avons réussi à casser des mots de passe à l'aide du logiciel John the Ripper que nous avons téléchargé sur Kali Linux sur notre VirtualBox. A l'aide de ce logiciel nous avons cassé des mots de passes avec différents modes, qui chacun d'entre eux proposent leur propre approche au brute forcing. Par exemple, nous avons utilisé le « Single Crack » mode, le Rule-Based Attack et le « External » mode permettant d'écrire des règles complexes sous forme de programme en C. Avec toutes ces techniques nous sommes venus à bout des hashes du fichier « password.txt » à l'aide d'un dictionnaire contenant des mots qui formaient la base des mots de passes à casser, s'appelant « animaux.txt ». Nous avons également analysé les performances du cassage de mots de passes et répondu à certains aspects théoriques du fonctionnement de John the Ripper.

Sources

1. <https://linuxconfig.org/password-cracking-with-john-the-ripper-on-linux>
2. <https://www.openwall.com/john/doc/MODES.shtml>
3. <https://security.stackexchange.com/questions/37072/what-exactly-is-single-mode-in-john-the-ripper-doing>
4. <http://www.cyberciti.biz/faq/unix-linux-password-cracking-john-the-ripper/>
5. <https://www.google.com/search?q=%22single%20crack%22%20mode%20%22john%20the%20ripper%22>
6. http://en.wikipedia.org/wiki/Gecos_field
7. <https://miloserdov.org/?p=5477#515>
8. <https://www.lanmaster53.com/2011/02/creating-complex-password-lists-with-john-the-ripper/>
9. <https://www.thecrazyprogrammer.com/2016/11/caesar-cipher-c-c-encryption-decryption.html>